Natalyx MVP Fixes

Work Package 09: Documents, active case, and provider handoffs

L. Rhodes (plan owner) - A. Zhao (technical review requested)

2026-07-10

Contents

1 Work Package 09: Documents, active case, and provider handoffs **2**

1.1 Purpose and outcome 2

1.2 Verified current-state evidence 3

1.3 Architecture and contracts 3

1.4 Explicit PR sequence 10

1.5 Cross-repository coordination 22

1.6 Test and acceptance matrix 22

1.7 Risks and decisions 23

1.8 Existing-work salvage 25

1.9 Ownership recommendation 27

1.10 Definition of done 27

1 Work Package 09: Documents, active case, and provider handoffs

Review draft only. Ownership and sequencing remain recommendations until Luke and Alan approve the plan together.

Plan	Value
Work package	WP09
Plan file	`WP09 - Documents, active case, and provider handoffs.md`
Proposed PRs	P09-01, P09-02, P09-03, P09-04, P09-05
Inspection snapshot	2026-07-10 20:12 America/New_York

1.1 Purpose and outcome

Problem. Current documents are metadata-only; the dirty provider branch is unreviewed and can over-project facts. There is no durable private S3/KMS/quarantine/recovery pipeline.

Why this package exists. It creates a reviewable boundary so the programme can progress without mixing product, data, security, infrastructure and rollout concerns in one oversized change.

Completed outcome. A secure document lifecycle, resilient storage/scan/download pipeline, usable active-case surfaces, and consent-scoped immutable provider snapshots with operational review.

Explicit non-goals.

- No ambient provider case access

- No clinical approval by Natalyx
- No direct public objects
- No automatic promotion of AI/IP assertions

1.2 Verified current-state evidence

Classification is explicit: **verified** is observed code/PR/live behavior; **verified limitation** records an evidence gap; **design authority** is an approved planning source; **design decision** is proposed future behavior. None is silently treated as another.

ID	Class	Repository / ref	File, construct or location	Finding
E-006	verified	app / PR #122@e853821	PR comment Review round 2 addressed and changed workflow/tests	Updated PR #122 reports 499 tests plus return_to, TTL, CAS, self-invite, lens and Learn fail-closed fixes; green checks were observed. These are salvage candidates, not blanket merge approval.
E-012	verified	app / PR #122@e853821	app/storage/invitations.py and PR review-round comment	The updated case invitation work adds 14-day ceiling, CAS transitions, mismatch confirmation, self-invite refusal, return_to preservation and paired lens tests; it has no Node 0 workspace target.
E-018	verified	app / PR #124@84a5a84	app/storage/documents.py:1-114; app/storage/schema.py:785-801	Documents are explicitly metadata-only; storage_uri/checksum fields exist but no durable upload, quarantine, scan, authorization-by-purpose, retention or recovery pipeline.
E-019	verified protected work	app / dirty feature/provider-exchange-layer-v0@84a5a84	app/provider_handoffs.py:109-133 and uncommitted handoff modules	The protected provider work is not a PR. Its broad GC-owner fact selection can include private/provisional data, so only selective port after provenance/purpose review is safe.

1.3 Architecture and contracts

- Private bucket, block-public-access, KMS, opaque keys, application authorization, size/type/checksum gates, quarantine/scan, audit, retention, and orphan cleanup are mandatory.
- Provider handoffs are purpose-bound snapshots with checksum/revision/expiry and consent; provider-visible items are allowlisted, not inferred from broad visibility.
- ECS replacement must not lose upload/task state; recovery resumes from durable metadata and object state.

Contract area	Package rule
Ownership boundary	`app`, `infra`; repository-specific PRs remain separate.
Entities/state	`case`, `case_invitation`, `document + document_version + upload`
Authorization	Authenticated subject/service plus entity membership, role, purpose, consent and expected revision; query parameters, links and UI state are never authority.
API/service	Intent/finalize/status/download/replace/delete commands. Membership-scoped reads and evidence commands.
Storage	Versioned document/upload/scan/object metadata. Handoff/packet/snapshot/transmission/evidence ledgers under migrations.
Audit	Use the common transition envelope and append-only source/event identifiers; redact tokens, raw documents, prompts and sensitive payloads.
Failure	Fail closed for authorization, provenance, money, document and PHI boundaries; expose a bounded actionable error and preserve retry/repair evidence.
Observability	Correlation, policy/schema/config version, transition and dependency result metrics without PHI/PII payload logging.
Compatibility	Additive/dual-compatible changes, explicit version pins, old/new revision window and named forward repair.
Privacy/PHI	Synthetic only through A2; approved PII only at B1; PHI remains blocked until formal B2.

1.3.1 Applicable state machines

1.3.2 Paid case lifecycle (`case`)

Owner: **natalyx-app**. States: `enrollment_pending`, `active`, `paused`, `closed`, `cancelled`.

Transition: `none` -> `enrollment_pending`

- **Actor:** promotion service
- **Evidence:** byos.workspace_promotion_authorized.v1 + projection manifest
- **Idempotency key:** `promotion:{commitment}:v1`
- **Invalid transitions:** No authorization/duplicate workspace
- **Audit event:** `paid_case_created`
- **Retry:** Return same case
- **Recovery:** Forward-repair same promotion

Transition: `enrollment_pending` -> `active`

- **Actor:** authorized coordinator/domain service

- **Evidence:** approved onboarding/compatibility/intake/education evidence
- **Idempotency key:** `case:{id}:activate:{evidence_hash}`
- **Invalid transitions:** Missing/revoked evidence or GC consent
- **Audit event:** `case_activated`
- **Retry:** No duplicate activation/invoice
- **Recovery:** Return pending with unmet checklist

Transition: `active -> paused`

- **Actor:** authorized commercial/operations policy
- **Evidence:** audited non-critical pause reason
- **Idempotency key:** `case:{id}:pause:{event}`
- **Invalid transitions:** Safety-critical access cannot be paused
- **Audit event:** `case_paused`
- **Retry:** Idempotent
- **Recovery:** Resume after evidence; preserve entitled docs

Transition: `paused -> active`

- **Actor:** authorized operator/domain service
- **Evidence:** pause reason resolved
- **Idempotency key:** `case:{id}:resume:{event}`
- **Invalid transitions:** Unresolved safety/authorization block
- **Audit event:** `case_resumed`
- **Retry:** Idempotent
- **Recovery:** Escalate manual review

Transition: `active|paused -> closed`

- **Actor:** authorized coordinator
- **Evidence:** birth/close or completed termination handoff evidence
- **Idempotency key:** `case:{id}:close:{evidence_hash}`
- **Invalid transitions:** Open critical obligations
- **Audit event:** `case_closed`
- **Retry:** No-op if same evidence
- **Recovery:** Reopen only by exceptional audited event

Transition: `enrollment_pending|active|paused -> cancelled`

- **Actor:** authorized operator under policy
- **Evidence:** withdrawal/non-clearance/cancellation + financial disposition
- **Idempotency key:** `case:{id}:cancel:{request}`
- **Invalid transitions:** Cannot erase records/refund ledger
- **Audit event:** `case_cancelled`
- **Retry:** Idempotent
- **Recovery:** Replacement is a new case/workspace policy event

1.3.3 Paid-case membership invitation (`case_invitation`)

Owner: **natalyx-app**. States: `issued`, `pending_identity`, `identity_bound`, `mismatch_pending`, `issuer_confirmed`, `consented`, `redeemed`, `declined`, `revoked`, `expired`, `superseded`.

Transition: `none -> issued`

- **Actor:** authorized IP case member
- **Evidence:** enrollment_pending/active case + recipient binding
- **Idempotency key:** `case-invite:{case}:{role}:{generation}`
- **Invalid transitions:** Self/member/active-GC/unauthorized
- **Audit event:** `case_invite_issued`
- **Retry:** Return current; supersede prior live GC invite
- **Recovery:** Issue corrected invite

Transition: `issued -> pending_identity`

- **Actor:** recipient
- **Evidence:** valid addressed token landing
- **Idempotency key:** `case-invite:{id}:land`
- **Invalid transitions:** Expired/revoked
- **Audit event:** `case_invite_opened`
- **Retry:** Safe repeat
- **Recovery:** Authenticate with return_to

Transition: `pending_identity -> identity_bound|mismatch_pending`

- **Actor:** auth provider
- **Evidence:** verified subject/email
- **Idempotency key:** `case-invite:{id}:bind:{subject}`
- **Invalid transitions:** Terminal/duplicate/different subject
- **Audit event:** `case_invite_bound|mismatch`
- **Retry:** CAS protects terminal
- **Recovery:** Issuer confirmation or corrected invite

Transition: `mismatch_pending -> issuer_confirmed`

- **Actor:** authorized issuer
- **Evidence:** explicit reviewed mismatch confirmation
- **Idempotency key:** `case-invite:{id}:confirm:{issuer}`
- **Invalid transitions:** Issuer unauthorized/recipient changed
- **Audit event:** `case_invite_mismatch_confirmed`
- **Retry:** CAS no-op
- **Recovery:** Revoke and reissue

Transition: `identity_bound|issuer_confirmed -> consented`

- **Actor:** invitee

- **Evidence:** paid-case role/privacy consent version
- **Idempotency key:** `case-invite:{id}:consent:{version}`
- **Invalid transitions:** Stale/missing consent
- **Audit event:** `case_invite_consented`
- **Retry:** Idempotent
- **Recovery:** Present current consent

Transition: `consented -> redeemed`

- **Actor:** invitation service
- **Evidence:** single transaction creates person/party/membership
- **Idempotency key:** `case-invite:{id}:redeem`
- **Invalid transitions:** Existing member/active GC/expired/revoked
- **Audit event:** `case_invite_redeemed`
- **Retry:** Return same membership
- **Recovery:** Rollback entire transaction; forward repair from invite

Transition: `issued|pending_identity|identity_bound|mismatch_pending|issuer_confirmed|consented -> declined|revoked|expired|superseded`

- **Actor:** invitee/issuer/system
- **Evidence:** explicit decline/revoke/TTL/new generation
- **Idempotency key:** `case-invite:{id}:terminal:{event}`
- **Invalid transitions:** No terminal overwrite
- **Audit event:** `case_invite_terminal`
- **Retry:** Idempotent CAS
- **Recovery:** Fresh invitation only

1.3.4 Document lifecycle (`document + document_version + upload`)

Owner: **natalyx-app; storage in natalyx-infra**. States: `upload_requested`, `uploading`, `quarantined`, `scanning`, `available`, `review`, `approved`, `replaced`, `deleted`, `failed`.

Transition: `none -> upload_requested`

- **Actor:** authorized case member
- **Evidence:** document purpose/type/size intent
- **Idempotency key:** `upload:{case}:{client_request}`
- **Invalid transitions:** Unauthorized/type/size/retention block
- **Audit event:** `upload_requested`
- **Retry:** Return same intent
- **Recovery:** Expire/orphan intent

Transition: `upload_requested -> uploading`

- **Actor:** client/storage service
- **Evidence:** authorized upload starts

- **Idempotency key:** `upload:{id}:start`
- **Invalid transitions:** Expired intent/wrong key
- **Audit event:** `upload_started`
- **Retry:** Multipart resume
- **Recovery:** Abort and mark failed/orphan cleanup

Transition: `uploading` -> `quarantined`

- **Actor:** finalize service
- **Evidence:** object exists + size/checksum/content sniff
- **Idempotency key:** `upload:{id}:finalize:{checksum}`
- **Invalid transitions:** Mismatch/missing object
- **Audit event:** `upload_quarantined`
- **Retry:** Repeat verify
- **Recovery:** Delete bad object; request new upload

Transition: `quarantined` -> `scanning`

- **Actor:** scan worker
- **Evidence:** durable queued task
- **Idempotency key:** `scan:{version}:{engine_version}`
- **Invalid transitions:** Already available/deleted
- **Audit event:** `scan_started`
- **Retry:** Leased retry
- **Recovery:** Lease expiry requeues after ECS replacement

Transition: `scanning` -> `available|failed`

- **Actor:** scan service
- **Evidence:** signed clean/malicious/error result
- **Idempotency key:** `scan:{version}:{result_id}`
- **Invalid transitions:** Unknown result/engine
- **Audit event:** `scan_completed|scan_failed`
- **Retry:** Inbox replay no-op
- **Recovery:** Remain quarantined on timeout/error; security review

Transition: `available` -> `review|approved`

- **Actor:** authorized participant/reviewer
- **Evidence:** purpose-specific review/evidence
- **Idempotency key:** `document:{version}:review:{event}`
- **Invalid transitions:** Wrong role/stale version
- **Audit event:** `document_reviewed`
- **Retry:** Idempotent
- **Recovery:** New review revision

Transition: `available|review|approved` -> `replaced`

- **Actor:** authorized owner
- **Evidence:** new clean version linked
- **Idempotency key:** `document:{id}:replace:{new_version}`
- **Invalid transitions:** New version not available
- **Audit event:** `document_replaced`
- **Retry:** Return current version
- **Recovery:** Keep prior per retention; roll current pointer forward

Transition: `available|review|approved|replaced|failed -> deleted`

- **Actor:** authorized policy job/operator
- **Evidence:** retention/delete request and no hold
- **Idempotency key:** `document:{version}:delete:{request}`
- **Invalid transitions:** Legal hold/provider obligation
- **Audit event:** `document_deleted`
- **Retry:** Tombstone idempotent
- **Recovery:** Object-delete retry/orphan alarm; metadata/audit retained

1.3.5 Data authorship/provenance rules

- Every assertion/revision records subject_ref, semantic_key, author_subject/person/role, authorship_class, provenance, verification_status, visibility, purpose, source_ref, derived_from, supersedes_id, promotion_event_id, policy version and immutable timestamps.
- Class 1 defaults IP-private; class 2 defaults IP-private/internal and visibly says reported by the intended parent, not confirmed by the GC.
- Class 3 is GC-authored and shared only per field/purpose; class 4 is GC-only private; class 5 requires an evidence-linked role-gated reviewer/provider rail.
- GC confirmation appends a class-3 revision referencing the class-2 assertion. Relationship answers can coexist; disagreement is not an overwrite.
- Unselected candidates, raw health assertions, ranking scores and private IP notes do not promote. Derived values inherit the weakest source status.
- Copying, promotion, generic proposal approval, IP assertion or AI inference can never create Natalyx-reviewed, provider-confirmed, medically cleared, legally cleared or insurance-verified truth.

1.3.6 Durable document and S3 contract

1.3.6.1 Storage

- Private versioned quarantine bucket and clean vault with block-public-access, SSL-only and KMS encryption.
- App can create short-lived unique upload targets in quarantine but cannot read unscanned content; scanner moves/copies only clean versions to vault.
- Object key: env/{org_id}/{case_id}/{document_id}/{version_id}/{generated_object_id}; no names, emails, filenames or clinical labels.
- Authorization is always a Postgres membership/role/visibility/consent decision independent of the key.

- CloudTrail S3 data events and app document_access_event records provide purpose-aware access evidence.

1.3.6.2 Upload

- Configurable maximum size; provisional 25 MiB awaits D-DOC-02.
- Initial proposed allowlist PDF/JPEG/PNG; DOCX only after scanner/archive review; no macro-enabled Office formats.
- Unicode-normalize/sanitize display filename; byte-sniff MIME, expected length and required SHA-256 checksum.
- Never reuse a key. Finalize verifies object version, HeadObject size/checksum/type and upload-session ownership.
- S3 event -> durable queue -> scanner -> signed clean/rejected/error result; unavailable/timed-out scan remains quarantined.

1.3.6.3 Download

- App authenticates and authorizes exact version/purpose, records access event, then returns a very short-lived clean-vault GET with safe content disposition.
- App proxy is reserved for justified transformation/audit cases, not the default durable path.

1.3.6.4 Recovery

- Upload sessions/tasks live in Postgres/queue so ECS replacement does not lose them; leases expire and retry idempotently.
- Replacement creates a new immutable version and supersedes the prior current pointer.
- Deletion is an audited tombstone followed by retention/legal-hold controlled purge; object-delete failures alert and retry.
- Orphan reconciliation handles expired intents and objects without document versions; lifecycle aborts incomplete multipart uploads.
- Provider share uses a purpose-bound snapshot/checksum/expiry, not direct object-key authority.

1.4 Explicit PR sequence

Order	ID	Title	Repository	Dependencies	Gate	Size	Readiness
1	P09-01	Define document lifecycle, authorization, and retention contract	app	P00-01, P02-01	A2	Medium	Blocked by decision
2	P09-02	Provision private encrypted document and quarantine storage	infra	P09-01, P13-02	A2	Large	Dependencies unmet

Order	ID	Title	Repository	Dependencies	Gate	Size	Readiness
3	P09-03	Implement resilient document upload, scan, and download	app	P09-02, P02-03	A2	Exceptional	Dependencies unmet
4	P09-04	Complete active-case participant document and progress surfaces	app	P03-03, P07-04, P09-03, P11-03	A2	Exceptional	Dependencies unmet
5	P09-05	Implement consent-scoped provider handoff snapshots and operations	app	P04-02, P09-03, P09-04, P10-02	A2	Exceptional	Dependencies unmet

1.4.1 P09-01 - Define document lifecycle, authorization, and retention contract

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A2 / Medium / Blocked by decision
Dependencies	P00-01, P02-01
Blocking decisions/checkpoints	D-DOC-01, D-DOC-02, D-PHI-01
Source / salvage	Current metadata-only documents.py, provider branch

1.4.1.1 Objective Record the document state machine, role/purpose authorization matrix, object-key independence, retention/deletion/replacement rules, and failure recovery before storage implementation.

1.4.1.2 Scope

- Upload/scan/available/review/replace/delete states
- Size/type/checksum and filename policy
- Presigned versus proxied download decision
- Orphan/retention jobs

1.4.1.3 Explicit non-goals

- No bucket or application code

1.4.1.4 Expected files or modules

- `docs/adr/ADR-00x-durable-documents.md`
- `docs/agents/documents.md`
- `docs/security/document-threat-model.md`

1.4.1.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Decision and threat model only.

1.4.1.6 Tests and validation Objective tests:

- Threat-model abuse cases
- state transition table review
- retention/legal-hold walkthrough

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.1.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.1.8 Rollout Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.1.9 Rollback or forward repair Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.1.10 Dependencies and parallel work Hard dependencies: P00-01, P02-01. Parallel opportunities: P09-03, P09-04, P09-05

1.4.1.11 Objective acceptance criteria

- ☐ Record the document state machine, role/purpose authorization matrix, object-key independence, retention/deletion/replacement rules, and failure recovery before storage implementation.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.1.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	application security, S3/KMS, privacy
Higher-capability review	Mandatory before merge

1.4.2 P09-02 - Provision private encrypted document and quarantine storage

Field	Plan
Repository / base	`infra` (`main`)
Gate / size / readiness	A2 / Large / Dependencies unmet
Dependencies	P09-01, P13-02
Blocking decisions/checkpoints	D-DOC-02, D-PHI-01
Source / salvage	Existing infra platform stack patterns

1.4.2.1 Objective Provision dev/private document buckets, KMS policy, block-public-access, lifecycle/quarantine events, least-privilege task roles, and audit logging behind PHI/billable guardrails.

1.4.2.2 Scope

- Private primary/quarantine storage
- KMS and task-role policy
- Lifecycle/orphan signals
- No public ACL/policy

1.4.2.3 Explicit non-goals

- No production/PHI activation
- No application upload

1.4.2.4 Expected files or modules

- `lib/stacks/platform-stack.ts`
- `lib/constructs/document-storage.ts`
- `test/document-storage.test.ts`
- `docs/agents/platform-stack.md`

1.4.2.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	No public API/route contract change.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	CDK resources and SSM outputs in dev, desired counts unchanged by default.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.2.6 Tests and validation Objective tests:

- CDK assertions
- IAM negative cases
- public-access-block
- encryption/lifecycle/event contract

Local validation:

- `npm test`
- `npm run build`
- `Synthesize the affected CDK stack with billable/live changes disabled.`

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.2.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.2.8 Rollout Synthesize and review first; deploy only through the guarded dev workflow with billable/desired-count defaults unchanged, exact revision recorded, and explicit confirmation outside this planning task.

1.4.2.9 Rollback or forward repair Return to the prior reviewed stack/task definition when compatible; otherwise keep resources fail-closed and forward-repair under the runbook. Never delete data-bearing resources as an automatic rollback.

1.4.2.10 Dependencies and parallel work Hard dependencies: P09-01, P13-02. Parallel opportunities: P09-04, P09-05

1.4.2.11 Objective acceptance criteria

- ☐ Provision dev/private document buckets, KMS policy, block-public-access, lifecycle/quarantine events, least-privilege task roles, and audit logging behind PHI/billable guardrails.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.2.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	AWS S3, KMS/IAM, CDK, security
Higher-capability review	Mandatory before merge

1.4.3 P09-03 - Implement resilient document upload, scan, and download

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A2 / Exceptional / Dependencies unmet
Dependencies	P09-02, P02-03
Blocking decisions/checkpoints	D-DOC-01, D-DOC-02
Source / salvage	Current metadata scaffold

1.4.3.1 Objective Implement multipart-safe upload intent/finalize, checksum/type/size validation, quarantine/scan transitions, authorized download, replacement, deletion, and task-recovery behavior.

1.4.3.2 Scope

- Opaque object keys and sanitized display names

- Durable upload states
- Malware/quarantine integration
- Presigned/proxy path per ADR
- Audit events

1.4.3.3 Explicit non-goals

- No public object URL
- No provider share by key

1.4.3.4 Expected files or modules

- `app/documents/service.py`
- `app/documents/storage.py`
- `app/routes/documents.py`
- `app/jobs/document_recovery.py`
- `tests/python/test_documents_e2e.py`

1.4.3.5 Change map

Area	Planned change
Schema/model	Versioned document/upload/scan/object metadata.
API/routes	Intent/finalize/status/download/replace/delete commands.
UI/product surface	No visible participant/operator UI change.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.3.6 Tests and validation

Objective tests:

- Oversize/type spoof
- checksum mismatch
- scan fail/timeout
- ECS task replacement
- orphan cleanup
- authorization

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.3.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.3.8 Rollout Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.3.9 Rollback or forward repair Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.3.10 Dependencies and parallel work Hard dependencies: P09-02, P02-03. Parallel opportunities: P09-01

1.4.3.11 Objective acceptance criteria

- ☐ Implement multipart-safe upload intent/finalize, checksum/type/size validation, quarantine/scan transitions, authorized download, replacement, deletion, and task-recovery behavior.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.3.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	S3, secure uploads, background jobs, authorization
Higher-capability review	Mandatory before merge

1.4.4 P09-04 - Complete active-case participant document and progress surfaces

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A2 / Exceptional / Dependencies unmet
Dependencies	P03-03, P07-04, P09-03, P11-03
Blocking decisions/checkpoints	D-COM-04, CHECK-ALAN-122-124
Source / salvage	PR #122 selective/direct reuse after checkpoint, PR #124 case UI

1.4.4.1 Objective

Expose role-scoped active-case tasks, documents, progress, waiting and safe pause states after activation while keeping the server projection authoritative.

1.4.4.2 Scope

- enrollment_pending versus active surfaces
- IP/GC lenses
- Documents/tasks/timeline/notifications
- Mobile journey orientation

1.4.4.3 Explicit non-goals

- No client-owned state transition
- No operator/provider leakage

1.4.4.4 Expected files or modules

- `app/case_home.py`
- `app/case_journey.py`
- `app/routes/case.py`
- `app/templates/case/`
- `tests/python/test_case_home.py`

1.4.4.5 Change map

Area	Planned change
Schema/model	None in this PR; any later schema change stays in its named migration PR.
API/routes	Membership-scoped reads and evidence commands.
UI/product surface	Participant control center and journey map backed by case projection.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.4.6 Tests and validation

Objective tests:

- IP/GC paired lenses
- pending/active/paused
- no membership
- malformed/stale projection
- mobile/no-JS/reduced-motion

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.4.7 Diagnostics and observability Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.4.8 Rollout Deploy behind the narrowest practical feature/config gate, verify the named synthetic flow and diagnostics on a known revision, then widen only at the associated programme gate.

1.4.4.9 Rollback or forward repair Disable the feature or return to the prior compatible image; retain append-only audit/ledger history and repair with a new event/revision rather than destructive mutation.

1.4.4.10 Dependencies and parallel work Hard dependencies: P03-03, P07-04, P09-03, P11-03. Parallel opportunities: P09-01, P09-02

1.4.4.11 Objective acceptance criteria

- ☐ Expose role-scoped active-case tasks, documents, progress, waiting and safe pause states after activation while keeping the server projection authoritative.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.4.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	FastAPI/Jinja, accessibility, authorization, state projection
Higher-capability review	Mandatory before merge

1.4.5 P09-05 - Implement consent-scoped provider handoff snapshots and operations

Field	Plan
Repository / base	`app` (`main`)
Gate / size / readiness	A2 / Exceptional / Dependencies unmet
Dependencies	P04-02, P09-03, P09-04, P10-02
Blocking decisions/checkpoints	D-PROV-01, D-PHI-01
Source / salvage	Protected provider-exchange worktree: selective port only after provenance fix

1.4.5.1 Objective Create purpose-bound, reviewed, checksummed provider packets from explicitly allowed facts/documents and operate send/confirm/revoke/reroute without ambient provider access.

1.4.5.2 Scope

- Packet revisions/snapshots/checksums
- Consent, recipient, purpose, expiry
- Operator route review and transmission outcomes
- Inbound evidence becomes proposal

1.4.5.3 Explicit non-goals

- No raw private/provisional bulk projection
- No provider truth without review

1.4.5.4 Expected files or modules

- `app/provider_handoffs.py`
- `app/storage/handoffs.py`
- `app/routes/operator_handoffs.py`
- `app/templates/internal/handoffs/`
- `tests/python/test_provider_handoffs.py`

1.4.5.5 Change map

Area	Planned change
Schema/model	Handoff/packet/snapshot/transmission/evidence ledgers under migrations.
API/routes	No public API/route contract change.
UI/product surface	Case-scoped operator queue and GC review.
Infrastructure/workflow	No cloud/infrastructure resource or workflow change.
Migration/backfill	No migration or backfill.
Security/privacy	Preserve existing fail-closed boundaries; validate the PR-specific privacy/security cases.
Architecture/docs/config	Document the contract, version pins and safe partial-merge behavior.

1.4.5.6 Tests and validation

Objective tests:

- Purpose allowlist
- revoked consent
- stale route
- snapshot immutability
- delivery retry
- private/provisional exclusion

Local validation:

- `python -m unittest discover -s tests/python`
- Run the focused test module(s) named above against SQLite and PostgreSQL where applicable.

Cloud validation: run only through Gate **A2** on a known revision, using synthetic data until B1 and no PHI until B2. A merge or green deployment is not gate acceptance.

1.4.5.7 Diagnostics and observability

Emit correlation/idempotency/policy/version identifiers, transition/result counters and bounded failure reasons; never log tokens, processor payloads, raw documents, prompts, PHI or unnecessary PII.

1.4.5.8 Rollout

Ship expand-only and dark by default; run the one-off migrator, verify readiness/old-revision compatibility, then enable writers/readers in a later compatible step.

1.4.5.9 Rollback or forward repair

Prefer application rollback within the expand/contract window and a new forward-repair migration. An irreversible schema reversal requires its own approval and backup evidence.

1.4.5.10 Dependencies and parallel work

Hard dependencies: P04-02, P09-03, P09-04, P10-02. Parallel opportunities: P09-01, P09-02

1.4.5.11 Objective acceptance criteria

- ☐ Create purpose-bound, reviewed, checksummed provider packets from explicitly allowed facts/documents and operate send/confirm/revoke/reroute without ambient provider access.
- ☐ Every listed objective test passes locally and at the required gate where applicable.
- ☐ Every explicit non-goal remains out of the diff and no protected worktree/branch is modified during extraction.
- ☐ Rollout/repair evidence is attached before merge; unresolved decisions remain blocked rather than encoded as guesses.

1.4.5.12 Ownership and review

Role	Recommendation
DRI	Alan
Implementer	Alan (proposed; pending consolidated-plan sign-off)
Reviewer	Luke
Final approver	Luke
Required expertise	provider workflows, privacy, document security, operations
Higher-capability review	Mandatory before merge

1.5 Cross-repository coordination

Repository	Authority after merge
`app`	routing, validation, authorization, participant/case/workflow truth, PHI policy and commercial domain
`infra`	AWS resources, IAM/KMS/network/deployment/backup/audit contracts

Merge order inside this package: `P09-01` → `P09-02` → `P09-03` → `P09-04` → `P09-05`.

Handoff rule: producer contract/version must merge and be pinned before its consumer enables the feature. During a partial merge, consumers fail closed or retain the last approved version; they do not fabricate data or silently broaden access.

Compatibility window: keep prior readers/writers and rollback image usable through the named gate; contract/migration PRs document the exact removal point.

1.6 Test and acceptance matrix

Test dimension	Method	Objective result
Happy path	Unauthorized object access; Oversize/type/spoof; Scan failure/quarantine; Partial upload/task loss; Snapshot immutability/revocation; Mobile documents	Expected state/event/UI and named evidence are produced once.
Authorization failure	Wrong/no subject, role, membership, purpose or consent	403/404 as appropriate; no write or data leak; audit safe failure.
Role differences	Separate IP, GC, operator, provider/service identities	Only the approved lens/projection/actions appear.
Retries/duplicates	Repeat same canonical request/event	Original result returned; no duplicate membership/case/invoice/document/event.
Concurrency	Two writers/claimants/migrators/workers	One valid transition; loser receives deterministic stale/conflict response.

Test dimension	Method	Objective result
Stale state	Old revision/config/terms/token/artifact	Fail closed or approved compatibility behavior; never silent coercion.
Malformed input	Boundary, encoding, size, enum, redirect and identifier corpus	Validation before side effects; safe error.
Unavailable dependency	Database, intelligence, processor, S3/scanner or auth unavailable	Explicit degraded/blocked behavior; no hallucinated success.
Partial failure	Crash between external effect, DB transaction and outbox	Retry/forward repair converges from durable evidence.
Logout/login/resume	Session expires/restarts mid-flow	Return to authorized current state; no query/link authority.
Mobile/accessibility	320/375/768 widths, keyboard, focus, reduced motion	Core task completes with truthful state and no clipped controls.
Synthetic cloud	Known dev revision and synthetic identities/data	Gate artifact records SHA, dependency status, audit and cleanup.
Audit/observability	Inspect events/metrics/logs	Versions, actor/authority, correlation and reason present; no sensitive payload.

1.7 Risks and decisions

Type	ID / risk	Owner	Affected PRs / latest point	Treatment
Blocking/product/compliance decision	D-DATA-01 - Which provisional IP assertions may the GC see, which GC answers may the IP see, and which fields survive promotion/provider projection?	Luke	P04-02, P06-02, P06-03, P07-03, P07-04, P09-05, P10-01, P10-02; Before P04-02	D-DATA-01 - Default deny; expose only explicit purpose-limited projections. Class 1/2 and class 4 never automatically cross roles.

Type	ID / risk	Owner	Affected PRs / latest point	Treatment
Blocking/product/compliance decision	D-COM-04 - Define evidence for enrollment funding confirmed, promotion authorization, and for onboarding/compatibility complete enough to move case active and earn/issue activation billing.	Luke	P07-02, P07-03, P07-04, P08-03, P09-04; Before P07-02	D-COM-04 - Funding confirmation is durable ledger evidence; promotion uses the sole typed authorization event; activation requires an explicit evidence checklist, actor and audit event.
Blocking/product/compliance decision	D-DOC-01 - Set retention/legal-hold/deletion and choose presigned versus app-proxied downloads by document class.	Luke	P09-01, P09-03; Before P09-03	D-DOC-01 - Purpose/role authorization independent of key; short-lived downloads; deletion tombstone/audit; legal/privacy review.
Blocking/product/compliance decision	D-DOC-02 - Choose maximum size/types, scanner/quarantine mechanism, timeout/retry and fail-closed handling.	Luke	P09-01, P09-02, P09-03; Before P09-02	D-DOC-02 - Narrow allowlist, checksum and content sniffing; unavailable scanner remains quarantined.
Blocking/product/compliance decision	D-PROV-01 - Define permitted recipients/purposes, GC preview/consent, expiry, verification level and exact fact/document allowlists.	Luke	P09-05; Before P09-05	D-PROV-01 - Class 1/2 excluded; class 4 only if GC explicitly selects for recipient/purpose; class 5 evidence linked.

Type	ID / risk	Owner	Affected PRs / latest point	Treatment
Blocking/product/compliance decision	D-PHI-01 - Approve data classification, vendors/BAAs, encryption/logging/access/incident/backup controls and prohibited data at each gate.	Luke	P09-01, P09-02, P09-05, P13-05, P13-06, P13-07; Before B1 for PII scope; before B2 for PHI	D-PHI-01 - B1 remains PII-only; B2 requires formal external security/privacy/compliance evidence.
Implementation risk	PHI exposure	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Malware	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Orphaned objects	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Stale provider packet	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan
Implementation risk	Dirty branch leakage	Alan or named PR DRI	Package PRs; before associated gate	Mitigate through the explicit tests, rollout and forward-repair plan

1.8 Existing-work salvage

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
app#112	9605d88e31bd	Source-first 81-node/12-cluster surface map, participant-renderer boundaries, wave plan and cross-repo seams.	P09-04	Selective port, then supersede after extraction	Catalogued; content remains to be reconciled into replacement PR acceptance tests.

Source	Head	Valuable content	Destination	Recommendation	Extraction status/safety
app#122	e85382150853	Case projection/lens surfaces, safe return_to, invitation TTL/CAS/self-member/one-GC constraints, transactional membership, fail-closed Learn, SQL-limited timeline, responsive/a11y tests and Python CI workflow.	P09-04	Retain pending Alan reconciliation; selective port or rebase only after architecture approval	Reinspected at latest head. It is exactly e853821 (no newer delta); retention strengthened, but final extraction waits for Alan checkpoint.
app#124	84a5a847fea7	Current consolidation of Node 0 questionnaire/guide/surfaces, GC onboarding, participant case shell, invitations, DS assets and large focused test suites.	P09-04	Retain unchanged as evidence; selective port/rewrite after checkpoint	Unextracted; Alan review explicitly incomplete and unresolved.
feature/provider-exchange-layer-v0	84a5a84	substantial uncommitted provider handoff/ops/document work	P09-01/P09-03/P09-05 after provenance/security review	Selective port from protected worktree	Do not stage, reset, stash, switch, commit, clean or overwrite.
main	current local	substantial uncommitted operator shell/design-system work	Not part of participant DS; review only if P09-05 operator UI needs approved internal recipes	Selective port from protected worktree	Preserve repo boundary and dirty worktree.

Package source inventory:

- Protected provider-exchange branch by selective port after review
- Current document metadata scaffold
- PR #122 case shell UX

1.9 Ownership recommendation

Alan owns implementation; Luke approves retention, provider purpose, and PHI boundary. External security/privacy and provider workflow review required.

PR	DRI	Implementer	Reviewer	Final approver	External/high-capability review
P09-01	Alan	Alan (proposed)	Luke	Luke	Mandatory
P09-02	Alan	Alan (proposed)	Luke	Luke	Mandatory
P09-03	Alan	Alan (proposed)	Luke	Luke	Mandatory
P09-04	Alan	Alan (proposed)	Luke	Luke	Mandatory
P09-05	Alan	Alan (proposed)	Luke	Luke	Mandatory

Luke decides product/lifecycle/commercial/privacy/PHI/provider policy and accepts gates. Alan proposes implementation design, decomposition, migrations, code, tests, rollout and repair. This is a recommendation pending Alan's review/sign-off, not a compulsory assignment.

1.10 Definition of done

- ☐ Every proposed PR is merged in dependency order or explicitly dispositioned, with its objective acceptance criteria and review record complete.
- ☐ All package blocking decisions are resolved by the named owner; no commercial/privacy/security value is guessed in code.
- ☐ Local, PostgreSQL, role/authorization, retry/concurrency, failure, mobile and synthetic-cloud evidence required by this package is attached.
- ☐ Cross-repository contracts and artifact/migration versions are pinned; partial-merge behavior is fail-closed or explicitly degraded.
- ☐ Observability is sufficient to identify revision, transition, dependency and safe failure without sensitive payloads.
- ☐ Existing PR/worktree value and reviewer findings are extracted before closure; no cleanup occurs without team confirmation.
- ☐ The associated programme gate is accepted by Luke and any required external reviewer; tests/deploy alone do not establish B1/B2.